



INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO

Ingeniería en Sistemas Computacionales
Academia de Sistemas Distribuidos
Computer Security



PRÁCTICA NO. 5

Acceso Inicial al Sistema Operativo

Alumno: Contla Mota Luis Andrés

No. de Boleta: 2022630540

Grupo: 6CV3

Profesor: M.B.A Rodrigo Ojeda Santillán

Objetivo de la Práctica

Comprender y reproducir, en un entorno de laboratorio controlado y autorizado, las técnicas modernas de acceso inicial (Initial Access, TA0001 de MITRE ATT&CK) a un sistema operativo Linux, así como la fase inmediata de enumeración post-acceso, con el fin de entender cómo un atacante obtiene su primer punto de apoyo, qué evidencia deja, y qué controles defensivos detienen cada vector.

Objetivos Específicos

- Mapear los vectores de acceso inicial vigentes en 2026 al marco MITRE ATT&CK (T1078 Valid Accounts, T1110 Brute Force, T1190 Exploit Public-Facing Application, T1133 External Remote Services).
- Reproducir un ataque de fuerza bruta / password spraying controlado contra SSH y observar su detección y bloqueo (Fail2Ban, logs de auditoría).
- Comprender el abuso de credenciales válidas como vector dominante y por qué evade las defensas perimetrales tradicionales.
- Ejecutar enumeración post-acceso automatizada (LinPEAS) para identificar rutas de escalamiento de privilegios, entendiendo que estas herramientas tienen firmas detectables.
- Aplicar y validar controles defensivos: MFA, claves en lugar de contraseñas, principio de menor privilegio y monitoreo.

Introducción

El acceso inicial es el momento en que un adversario cruza la frontera de externo a interno: deja de preparar el ataque y obtiene su primer punto de apoyo dentro del sistema o la red. En cinco años, el panorama de cómo se logra ese acceso cambió radicalmente. El temario original asumía un mundo donde el ataque típico era explotar un servicio vulnerable o adivinar una contraseña débil. Hoy, el vector dominante es completamente distinto.

Según reportes de inteligencia de amenazas recientes, aproximadamente el 75% de las brechas en aplicaciones web involucran credenciales robadas, y las cuentas válidas (T1078) junto con el phishing (T1566) son consistentemente las dos técnicas de acceso inicial más utilizadas. El atacante moderno frecuentemente no "hackea": inicia sesión con credenciales legítimas compradas en mercados clandestinos o robadas por infostealers, y al hacerlo, las defensas perimetrales no ven nada anómalo.

Esta práctica aborda los cuatro vectores de Initial Access más relevantes para entornos Linux en 2026: Valid Accounts (T1078), Brute Force (T1110), Exploit Public-Facing Application (T1190) y External Remote Services (T1133). A través de seis laboratorios progresivos, se reproduce cada vector en un entorno aislado y controlado, se analiza la evidencia que deja, y se configuran y validan los controles defensivos que los neutralizan.

El marco MITRE ATT&CK (TA0001) proporciona la taxonomía estructurada que permite clasificar cada acción del laboratorio dentro del comportamiento adversario real observado en incidentes documentados. Esta vinculación entre ejercicio práctico y taxonomía es lo que convierte el laboratorio en formación defensiva efectiva: no se aprenden técnicas aisladas, sino la cadena completa del adversario y cómo interrumpirla en cada eslabón.

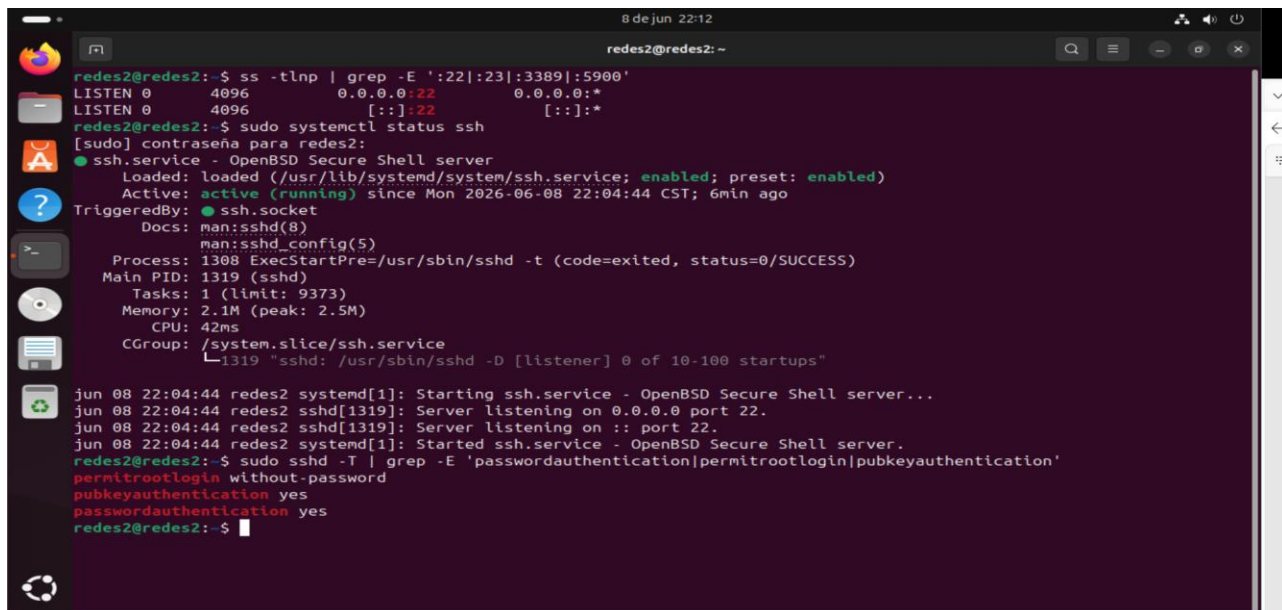
Desarrollo — Laboratorios

Laboratorio 1 — Línea Base y Superficie de Acceso Remoto

Objetivo: Identificar los servicios de acceso remoto expuestos en la máquina víctima, estableciendo la superficie por la cual se puede intentar el acceso inicial.

Técnica MITRE ATT&CK: T1133 — External Remote Services. La identificación de servicios expuestos es el paso previo al abuso de servicios remotos.

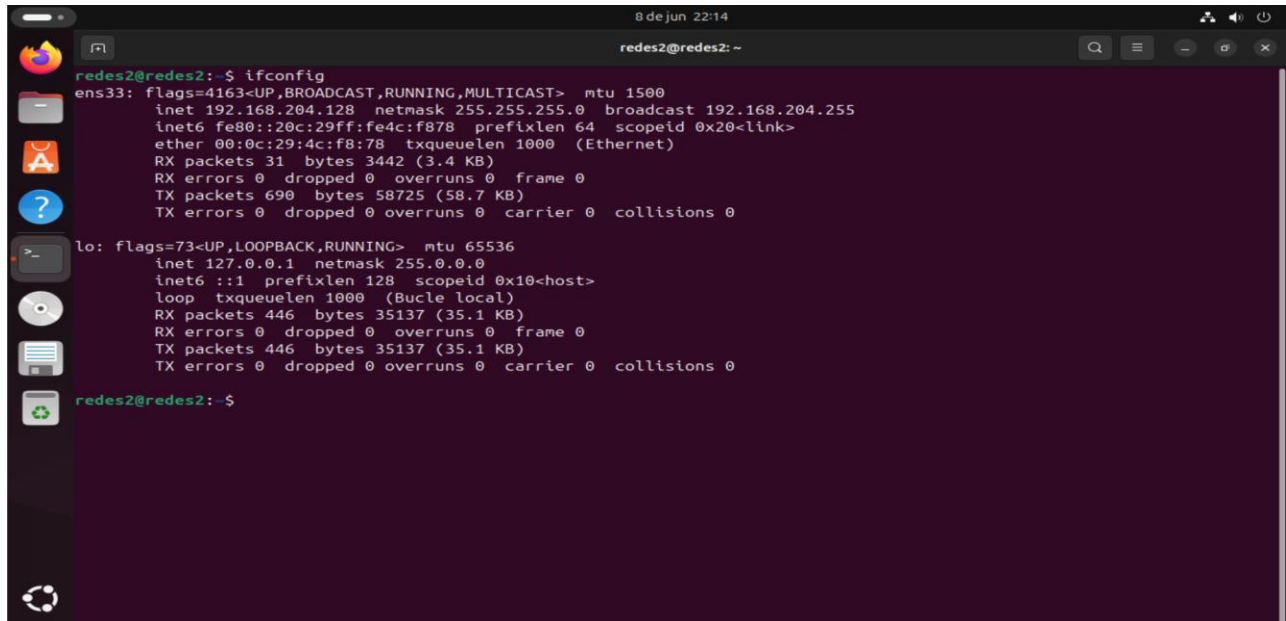
Validación de puerto de la máquina víctima:



```
redes2@redes2: ~  
$ ss -tlnp | grep -E ':22|23|3389|5900'  
LISTEN 0      4096      0.0.0.0:22      0.0.0.0:*  
LISTEN 0      4096      [::]:22       [::]:*  
redes2@redes2: ~  
$ sudo systemctl status ssh  
[sudo] contraseña para redes2:  
● ssh.service - OpenBSD Secure Shell server  
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: enabled)  
   Active: active (running) since Mon 2026-06-08 22:04:44 CST; 6min ago  
 TriggeredBy: ● ssh.socket  
    Docs: man:sshd(8)  
          man:sshd_config(5)  
   Process: 1308 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)  
    Main PID: 1319 (sshd)  
      Tasks: 1 (limit: 9373)  
     Memory: 2.1M (peak: 2.5M)  
        CPU: 42ms  
   CGroup: /system.slice/ssh.service  
           └─1319 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"  
  
jun 08 22:04:44 redes2 systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...  
jun 08 22:04:44 redes2 sshd[1319]: Server listening on 0.0.0.0 port 22.  
jun 08 22:04:44 redes2 sshd[1319]: Server listening on :: port 22.  
jun 08 22:04:44 redes2 systemd[1]: Started ssh.service - OpenBSD Secure Shell server.  
redes2@redes2: ~  
$ sudo sshd -T | grep -E 'passwordauthentication|permitrootlogin|pubkeyauthentication'  
permitrootlogin without-password  
pubkeyauthentication yes  
passwordauthentication yes  
redes2@redes2: ~
```

Fig. 1 — Validación del puerto de la VM víctima

Validación de IP desde la máquina víctima:



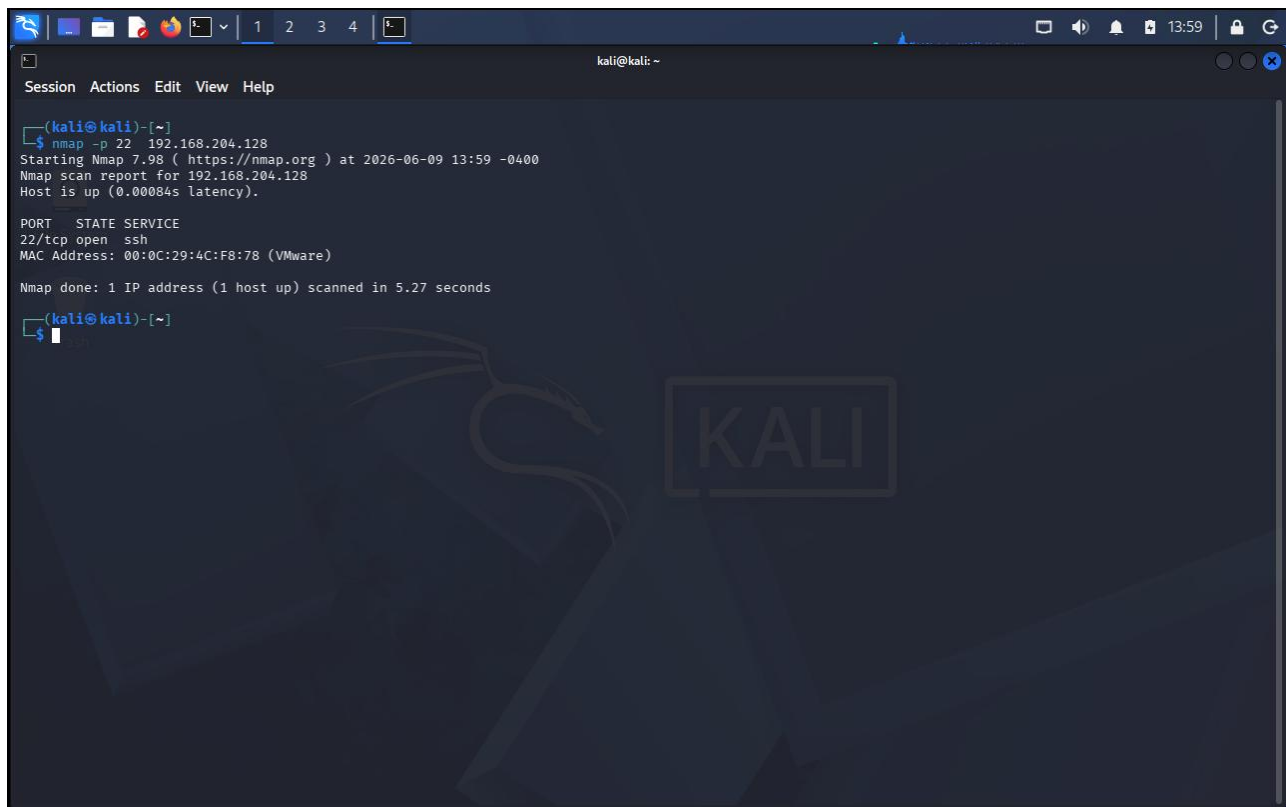
```
redes2@redes2:~$ ifconfig
ens33: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.204.128 netmask 255.255.255.0 broadcast 192.168.204.255
    inet6 fe80::20c:29ff:fe4c:f878 prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:4c:f8:78 txqueuelen 1000 (Ethernet)
    RX packets 31 bytes 3442 (3.4 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 690 bytes 58725 (58.7 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Bucle local)
    RX packets 446 bytes 35137 (35.1 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 446 bytes 35137 (35.1 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

redes2@redes2:~$
```

Fig. 2 — Validación de IP en la VM atacante (Kali)

Escaneo del puerto SSH desde Kali con Nmap:



```
kali@kali:~$ nmap -p 22 192.168.204.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-09 13:59 -0400
Nmap scan report for 192.168.204.128
Host is up (0.00084s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 00:0C:29:4C:F8:78 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.27 seconds

kali@kali:~$
```

Fig. 3 — Escaneo de puerto 22 (SSH) desde la VM atacante

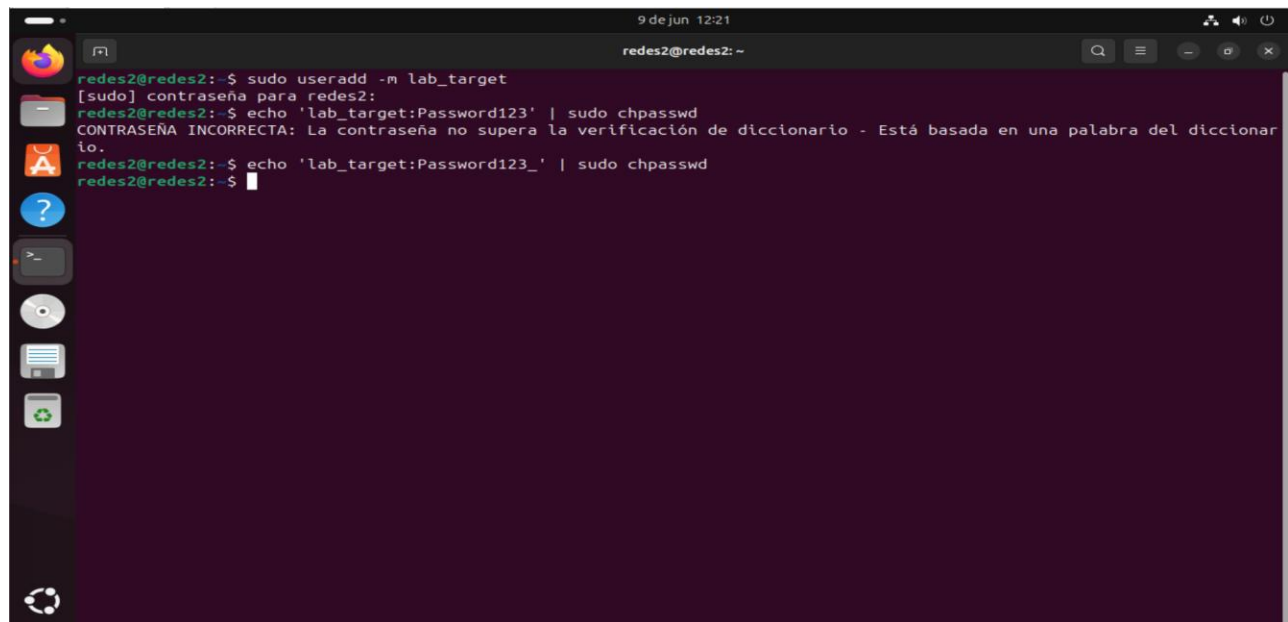
Interpretación: Se confirma que el puerto 22 (SSH) se encuentra activo y accesible desde la máquina atacante. Este es el servicio de acceso remoto que será objetivo en los laboratorios siguientes. La identificación de la superficie de ataque es el primer paso en la cadena de Initial Access.

Laboratorio 2 — Fuerza Bruta Controlada contra SSH (T1110)

Objetivo: Reproducir un ataque de fuerza bruta contra una cuenta de prueba con credencial débil para entender el vector y, principalmente, su detección.

Técnica MITRE ATT&CK: T1110 — Brute Force. Esta técnica engloba fuerza bruta, password spraying y credential stuffing. En este laboratorio se usa fuerza bruta directa con diccionario pequeño.

Creación del usuario de prueba con credencial débil (VM víctima):



```
redes2@redes2:~$ sudo useradd -m lab_target
[sudo] contraseña para redes2:
redes2@redes2:~$ echo 'lab_target:Password123' | sudo chpasswd
CONTRASEÑA INCORRECTA: La contraseña no supera la verificación de diccionario - Está basada en una palabra del diccionario.
redes2@redes2:~$ echo 'lab_target:Password123_' | sudo chpasswd
redes2@redes2:~$
```

Fig. 4 — Creación del usuario lab_target con contraseña débil

Generación del diccionario de contraseñas para el ataque:

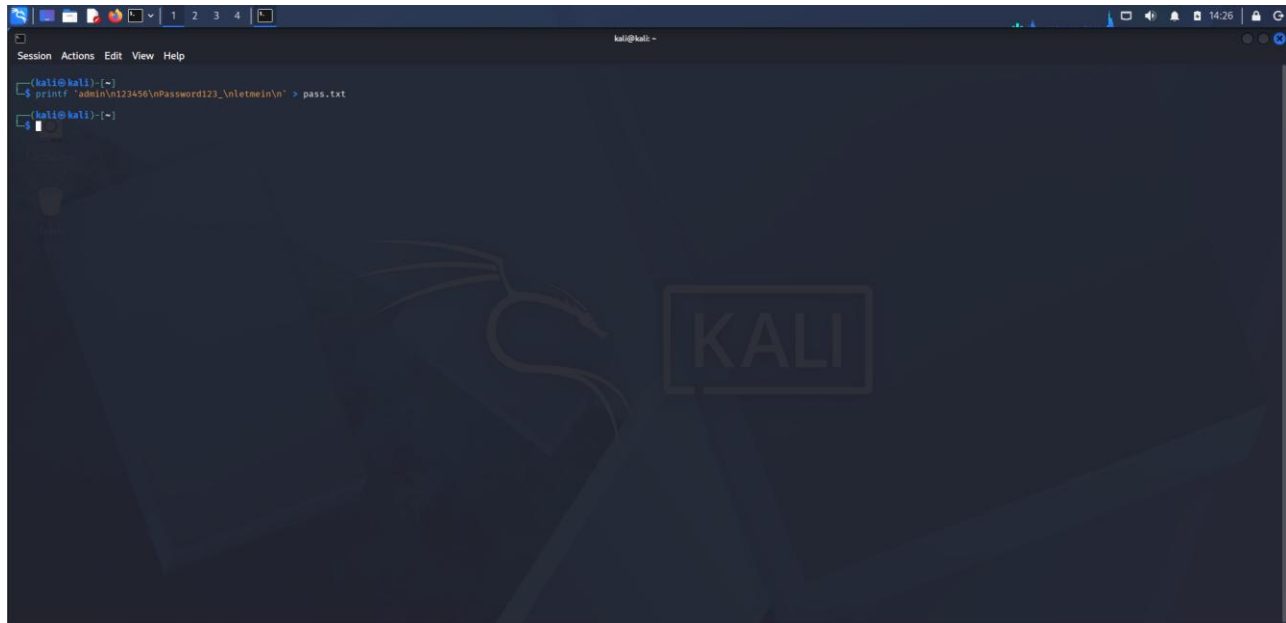


Fig. 5 — Diccionario de contraseñas (pass.txt)

Ejecución del ataque de fuerza bruta con Hydra:

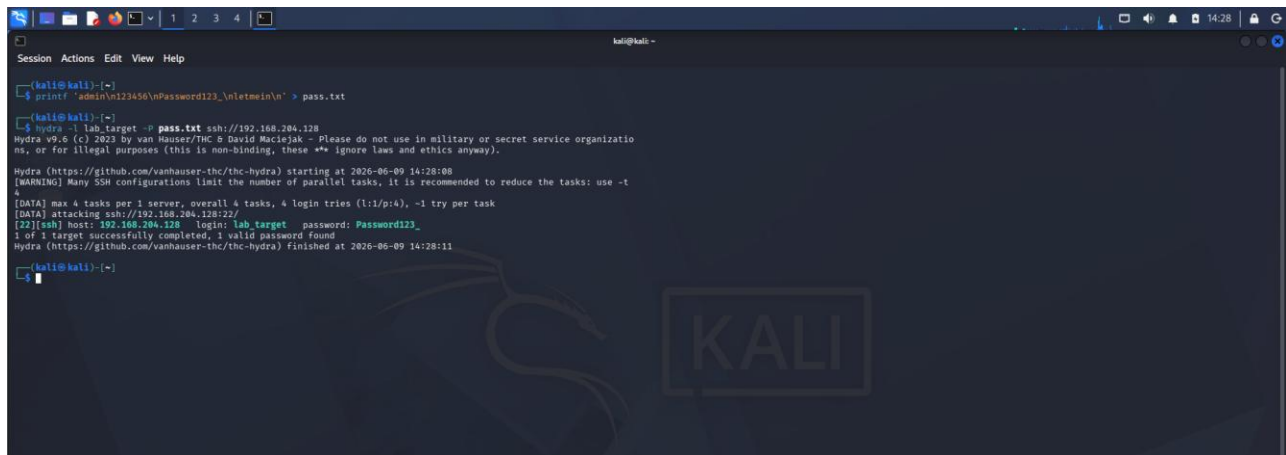


Fig. 6 — Hydra encuentra la credencial válida (Password123)

Interpretación: Hydra localiza la credencial en pocos intentos. La fuerza bruta directa es rápida pero ruidosa: genera múltiples intentos fallidos en los logs de autenticación, lo que facilita su detección. En contraste, el password spraying (una contraseña contra muchos usuarios) es más lento, pero evita los umbrales de bloqueo por cuenta.

Laboratorio 3 — Detección y Bloqueo con Fail2Ban

Objetivo: Configurar Fail2Ban como control defensivo y verificar que el ataque de fuerza bruta del Lab 2 queda bloqueado automáticamente.

Técnica MITRE ATT&CK (defensiva): Detección de T1110 — Brute Force. Fail2Ban analiza los logs de autenticación y bloquea vía iptables las IPs que superan el umbral de intentos fallidos.

Configuración del jail de SSH en Fail2Ban (maxretry=3, bantime=3600):

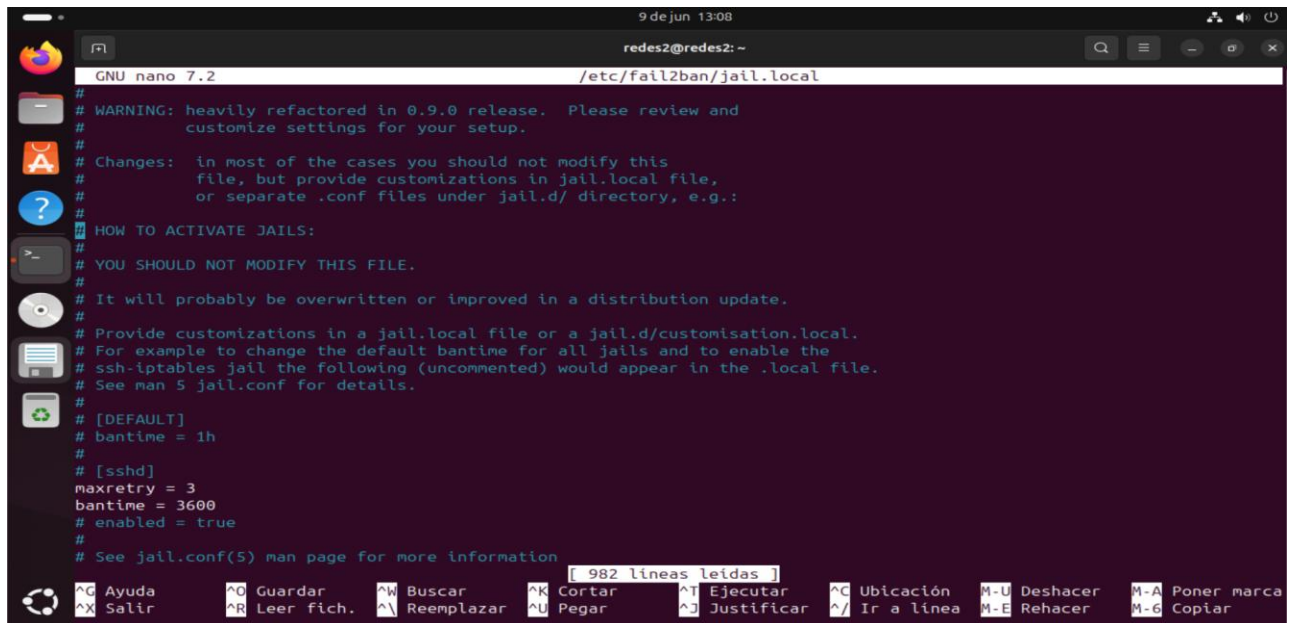


Fig. 7 — Configuración del jail [sshd] en jail.local

Repetición del ataque y verificación del bloqueo:

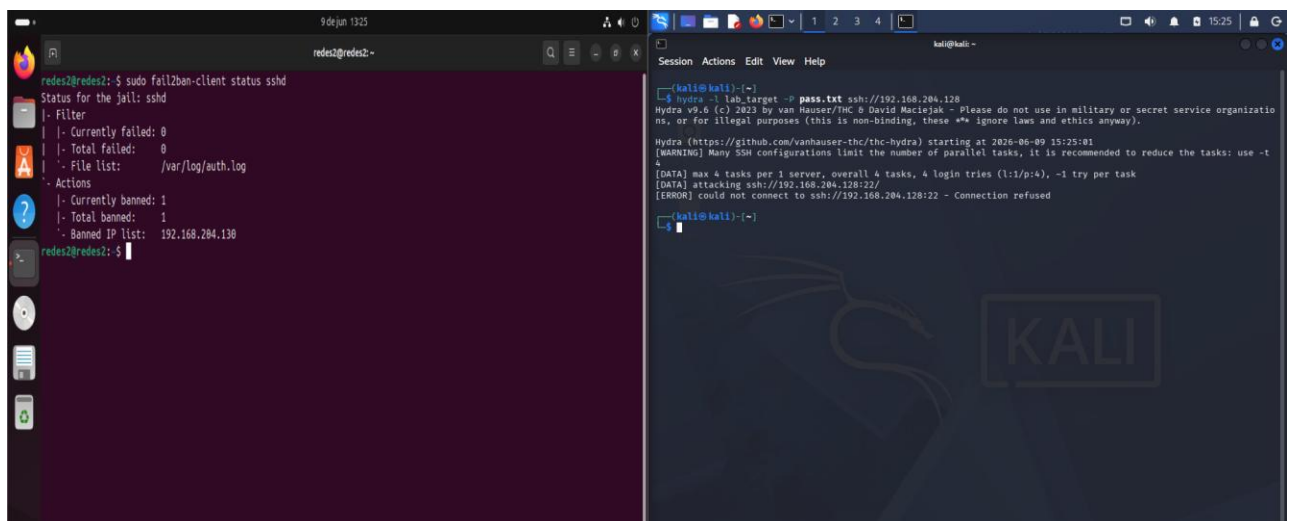


Fig. 8 — IP atacante baneada; Hydra no puede completar el ataque

Validación de logs de Fail2Ban:

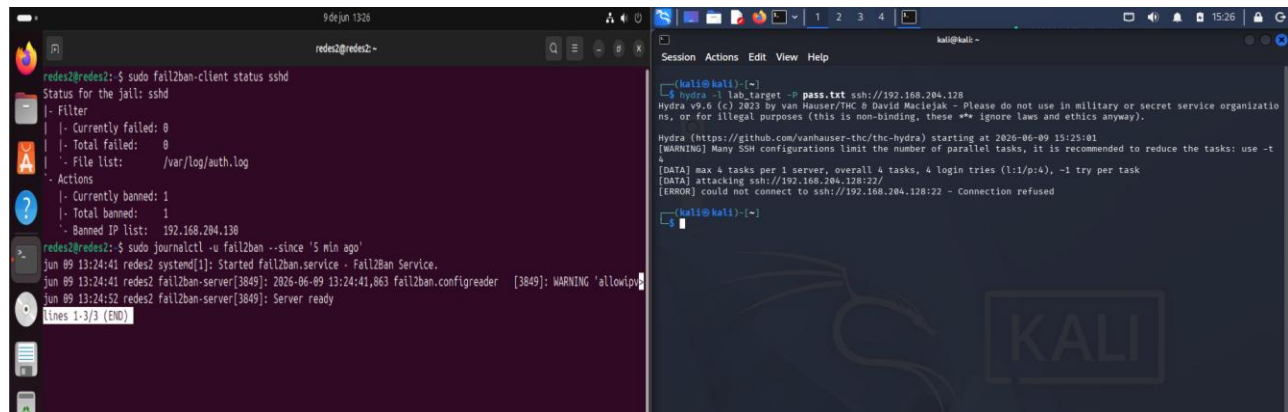


Fig. 9 — Evento de ban registrado en journalctl

Interpretación: Con maxretry=3, la IP atacante es baneada antes de que Hydra pueda completar el diccionario. Fail2Ban convierte un ataque de fuerza bruta viable en uno inviable al elevar el costo temporal del ataque. Sin embargo, no protege contra password spraying lento ni contra el uso de credenciales ya válidas (T1078).

Laboratorio 4 — Acceso por Credenciales Válidas vs. Clave Pública (T1078)

Objetivo: Comprender por qué las credenciales válidas son el vector dominante y por qué la autenticación por clave pública con contraseñas deshabilitadas neutraliza la fuerza bruta.

Técnica MITRE ATT&CK: T1078 — Valid Accounts. El atacante usa una credencial legítima para autenticarse; las defensas perimetrales no ven nada anómalo porque el login es válido.

Conexión SSH con la credencial obtenida (simulando T1078):

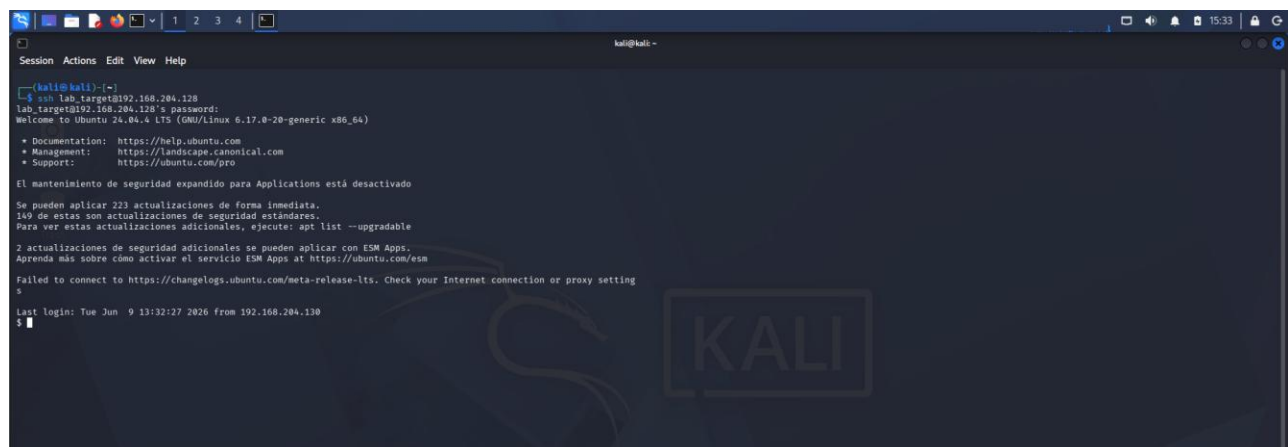
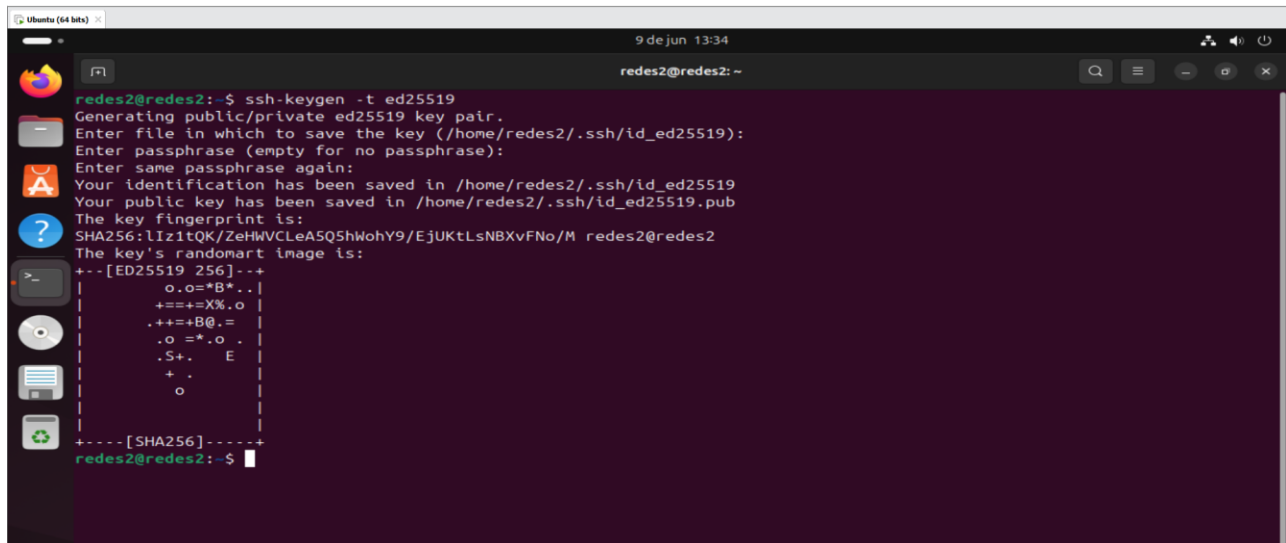


Fig. 10 — Acceso exitoso con lab_target y contraseña obtenida por Hydra

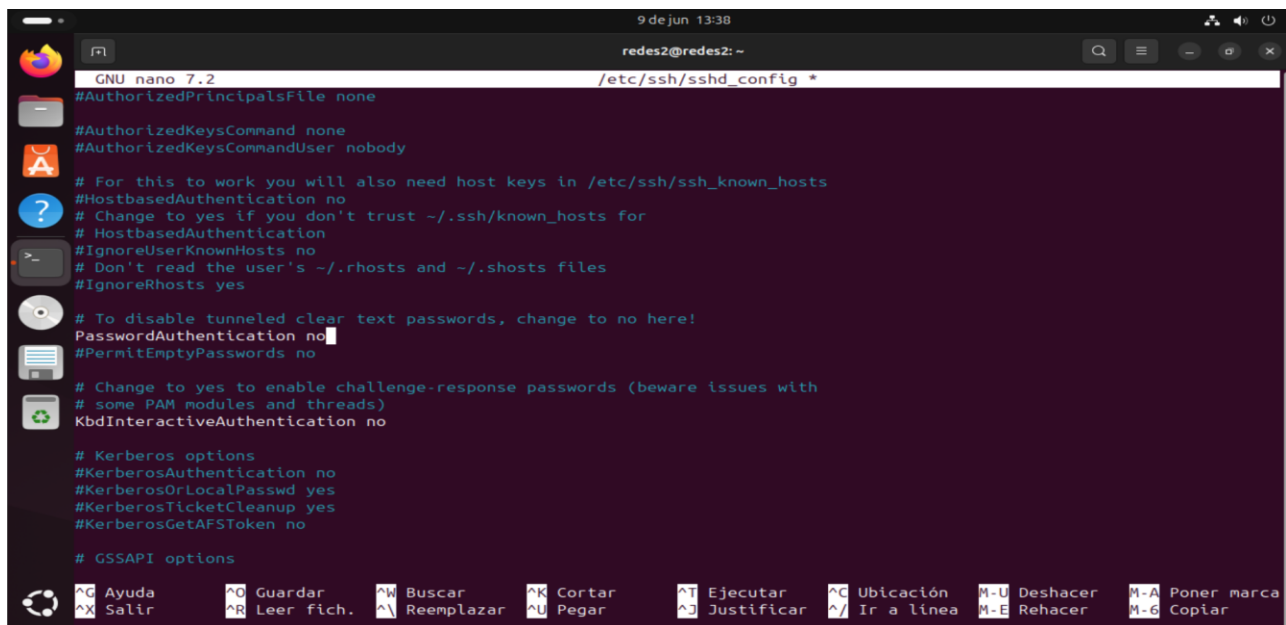
Migración a autenticación por clave pública (ssh-keygen + ssh-copy-id):



```
redes2@redes2:~$ ssh-keygen -t ed25519
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/redes2/.ssh/id_ed25519):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/redes2/.ssh/id_ed25519
Your public key has been saved in /home/redes2/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:1Iz1tQK/ZeHWVCLeA5Q5hWohY9/EjUKtLsNBXvFNo/M redes2@redes2
The key's randomart image is:
+--[ED25519 256]--+
  o.o=B*..|
  +==+X%.o
  .++=B@.=
  .o =*.o .
  .S+. E
  + .
  o
+-----[SHA256]-----+
redes2@redes2:~$
```

Fig. 11 — Generación de par de claves ed25519 y copia al servidor

Configuración de PasswordAuthentication no en sshd_config:



```
GNU nano 7.2 /etc/ssh/sshd_config *
#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
# IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication no
#PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
KbdInteractiveAuthentication no

# Kerberos options
#KerberosAuthentication no
#KerberosOrLocalPasswd yes
#KerberosTicketCleanup yes
#KerberosGetAFSToken no

# GSSAPI options
```

Fig. 12 — Parámetro PasswordAuthentication deshabilitado en sshd_config

Validación: Hydra ya no puede completar el ataque de fuerza bruta:

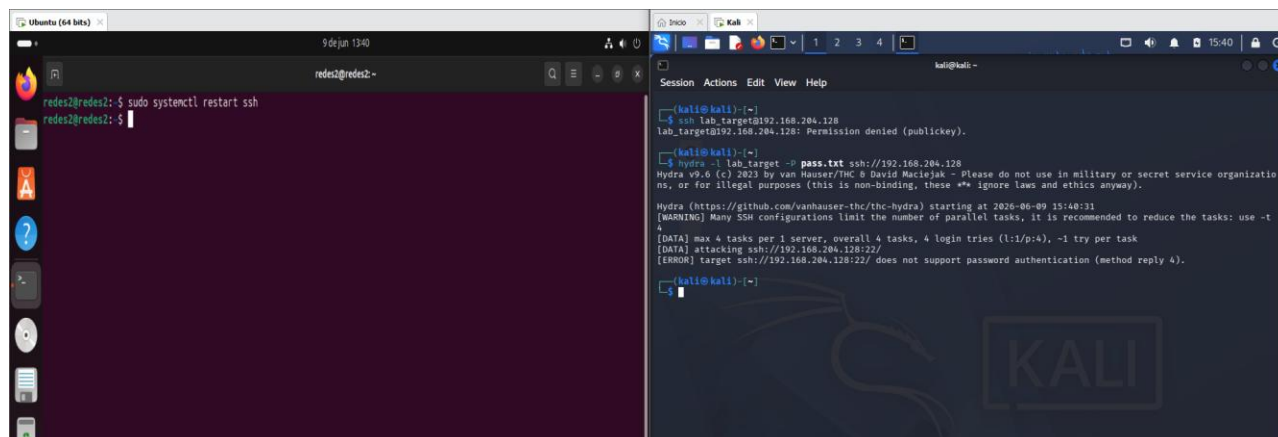


Fig. 13 — Hydra falla; la autenticación por contraseña está deshabilitada

Interpretación: Deshabilitar la autenticación por contraseña elimina completamente el vector de fuerza bruta, ya que no hay contraseña que probar. T1078 evade las defensas perimetrales porque el sistema no distingue entre un login legítimo y uno con credenciales robadas; la defensa efectiva es MFA resistente a phishing (FIDO2/passkeys) y la detección de anomalías de comportamiento.

Laboratorio 5 — Enumeración Post-Acceso con LinPEAS (TA0007)

Objetivo: Una vez con acceso, enumerar el sistema para identificar rutas de escalamiento de privilegios, replicando el comportamiento de un atacante tras el acceso inicial.

Técnica MITRE ATT&CK: TA0007 — Discovery. LinPEAS automatiza la enumeración de usuarios, servicios, permisos, binarios SUID, tareas programadas y configuraciones débiles.

Ejecución de LinPEAS en la VM víctima:



Fig. 14 — Descarga y ejecución de linpeas.sh

Resultados de LinPEAS — hallazgos de alto riesgo (rojo):

```
PATH (T1574.007)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#writable-path-abuses
/home/redes2/.local/bin:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin:/snap/bin
```

Fig. 15 — Resumen de hallazgos críticos de LinPEAS

```
Checking for Copy Fail (CVE-2026-31431) (T1068)
https://copy.fail/
https://www.cve.org/CVERecord?id=CVE-2026-31431
VULNERABLE: non-destructive AF_ALG/splice page-cache write triggered

Kernel Exploit Registry (T1068)
Operating system ..... Linux
Kernel release ..... 6.17.0-20-generic
Comparable version ..... 6.17.0.20
Data chunk limit ..... max 25 rows per KERNEL_CVE_DATA_* variable (1..21)
Kernel config source ..... /boot/config-6.17.0-20-generic
CVE: CVE-2025-38236 | Name: AF_UNIX MSG_00B UAF | Match data: pkg=linux-kernel,ver>=6.9.0 | Tags: 1 | Rank: Migrated from former standalone 1_system_information check
Kernel vulns found: 1

Checking for Dirty Frag (CVE-2026-43284 / CVE-2026-43500) (T1068)
https://ubuntu.com/blog/dirty-frag-linux-vulnerability-fixes-available
https://www.cve.org/CVERecord?id=CVE-2026-43284
https://www.cve.org/CVERecord?id=CVE-2026-43500
CVE-2026-43284 (xfrm-ESP): autoloadable: esp4 esp6 xfrm_user ipcomp6
CVE-2026-43500 (rxrpc): autoloadable: rxrpc
modprobe mitigation (xfrm-ESP): not found
modprobe mitigation (rxrpc): not found
Unprivileged user namespaces: enabled
LIKELY VULNERABLE to CVE-2026-43284 (xfrm-ESP).
LIKELY VULNERABLE to CVE-2026-43500 (rxrpc).
Mitigation: 'install esp4/esp6/rxrpc /bin/false' in /etc/modprobe.d/, then rmmod;
or systemctl kernel.unprivileged_usersns_clone=0; or apply distro patches.
```

Fig. 16 — Hallazgos adicionales marcados en rojo/amarillo

Enumeración manual: sudo, SUID y crontab:

```
9 de jun 22:54
redes2@redes2: ~
redes2@redes2:~$ sudo -l
Coincidiendo entradas por defecto para redes2 en redes2:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
  use_pty
El usuario redes2 puede ejecutar los siguientes comandos en redes2:
  (ALL : ALL) ALL
redes2@redes2:~$
```

Fig. 17 — sudo -l: comandos sudo permitidos para el usuario

```
9 de jun 22:56
redes2@redes2: ~
El usuario redes2 puede ejecutar los siguientes comandos en redes2:
(ALL : ALL) ALL
redes2@redes2:~$ find / -perm -4000 2>/dev/null
/usr/sbin/pppd
/usr/lib/xorg/Xorg.wrap
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/bin/pkexec
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/umount
/usr/bin/fusermount3
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/mount
/snap/core24/1643/usr/bin/chfn
/snap/core24/1643/usr/bin/chsh
/snap/core24/1643/usr/bin/gpasswd
/snap/core24/1643/usr/bin/mount
/snap/core24/1643/usr/bin/newgrp
/snap/core24/1643/usr/bin/passwd
/snap/core24/1643/usr/bin/su
/snap/core24/1643/usr/bin/umount
/snap/core24/1643/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core24/1643/usr/lib/openssh/ssh-keysign
/snap/core24/1643/usr/lib/polkit-1/polkit-agent-helper-1
/snap/core24/1587/usr/bin/chfn
/snap/core24/1587/usr/bin/chsh
```

Fig. 18 — `find / -perm -4000`: binarios SUID identificados

```
redes2@redes2:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
# You can also override PATH, but by default, newer versions inherit it from the environment
#PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6 * * 7 root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6 1 * * root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
#
redes2@redes2:~$
```

Fig. 19 — `/etc/crontab`: tareas programadas del sistema

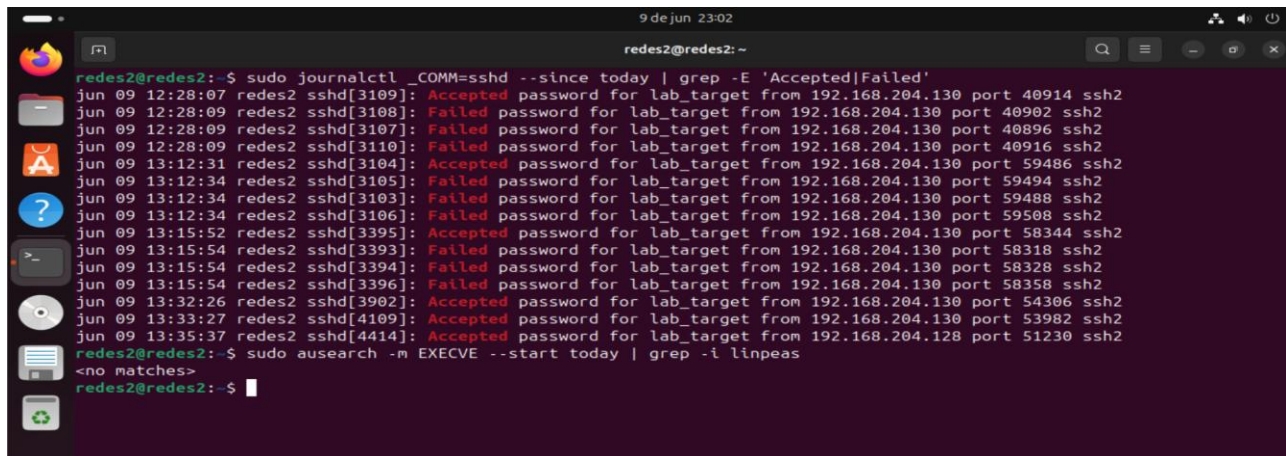
Interpretación: LinPEAS identifica rutas de escalamiento de privilegios coloreando los hallazgos por severidad. Los binarios SUID y los comandos sudo mal configurados son las rutas más comunes hacia root. Desde la perspectiva defensiva, LinPEAS tiene patrones de comportamiento detectables (bucles sobre permisos, acceso a `/etc/shadow`, enumeración masiva de SUID) que un SIEM o auditd puede correlacionar para identificar actividad de enumeración post-acceso.

Laboratorio 6 — Detección Defensiva y Limpieza

Objetivo: Cerrar el ciclo desde la perspectiva del defensor: detectar el acceso y la enumeración en los logs, y restaurar el sistema a su estado limpio.

Técnica MITRE ATT&CK (defensiva): Detección de TA0001 y TA0007. Los logs de autenticación y auditd permiten reconstruir la actividad del atacante.

Eventos de autenticación en journalctl (accesos exitosos y fallidos):



```
redes2@redes2:~$ sudo journalctl _COMM=sshd --since today | grep -E 'Accepted|Failed'
jun 09 12:28:07 redes2 sshd[3109]: Accepted password for lab_target from 192.168.204.130 port 40914 ssh2
jun 09 12:28:09 redes2 sshd[3108]: Failed password for lab_target from 192.168.204.130 port 40902 ssh2
jun 09 12:28:09 redes2 sshd[3107]: Failed password for lab_target from 192.168.204.130 port 40896 ssh2
jun 09 12:28:09 redes2 sshd[3110]: Failed password for lab_target from 192.168.204.130 port 40916 ssh2
jun 09 13:12:31 redes2 sshd[3104]: Accepted password for lab_target from 192.168.204.130 port 59486 ssh2
jun 09 13:12:34 redes2 sshd[3105]: Failed password for lab_target from 192.168.204.130 port 59494 ssh2
jun 09 13:12:34 redes2 sshd[3103]: Failed password for lab_target from 192.168.204.130 port 59488 ssh2
jun 09 13:12:34 redes2 sshd[3106]: Failed password for lab_target from 192.168.204.130 port 59508 ssh2
jun 09 13:15:52 redes2 sshd[3395]: Accepted password for lab_target from 192.168.204.130 port 58344 ssh2
jun 09 13:15:54 redes2 sshd[3393]: Failed password for lab_target from 192.168.204.130 port 58318 ssh2
jun 09 13:15:54 redes2 sshd[3394]: Failed password for lab_target from 192.168.204.130 port 58328 ssh2
jun 09 13:15:54 redes2 sshd[3396]: Failed password for lab_target from 192.168.204.130 port 58358 ssh2
jun 09 13:32:26 redes2 sshd[3902]: Accepted password for lab_target from 192.168.204.130 port 54306 ssh2
jun 09 13:33:27 redes2 sshd[4109]: Accepted password for lab_target from 192.168.204.130 port 53982 ssh2
jun 09 13:35:37 redes2 sshd[4414]: Accepted password for lab_target from 192.168.204.128 port 51230 ssh2
redes2@redes2:~$ sudo ausearch -m EXECVE --start today | grep -i linpeas
<no matches>
redes2@redes2:~$
```

Fig. 20 — Registro de eventos Accepted/Failed en sshd logs

Interpretación: Los logs de autenticación muestran la secuencia completa: intentos fallidos de fuerza bruta, el acceso exitoso con credencial válida y la sesión de enumeración. Esta traza permite al equipo de respuesta reconstruir la cadena de ataque y determinar el alcance de la brecha. La limpieza incluye eliminar la cuenta lab_target y restaurar la configuración SSH al estado anterior al laboratorio.

Conclusión

Esta práctica recorrió la cadena de ataque completa sobre Linux, desde mapear lo que está expuesto hasta detectar lo que hace un atacante una vez adentro. Y lo que queda claro al verla completa es que ninguna técnica aislada es suficiente, ni para atacar ni para defender.

La fuerza bruta sobre SSH funciona, pero avisa. Fail2Ban la detiene y los logs la registran con suficiente detalle para reconstruir el intento. El problema real no es que el ataque sea efectivo sino que el vector existe: mientras SSH acepte contraseñas, hay superficie. La solución no es afinar el bloqueo, es cerrar la entrada y migrar a claves públicas.

Las credenciales válidas son el caso opuesto: no avisan nada. Un login legítimo y uno robado se ven igual desde afuera. Ahí el perímetro ya no sirve y la defensa tiene que cambiar de lógica, dejar de preguntar si la contraseña es correcta y empezar a preguntar si el comportamiento tiene sentido. Eso requiere MFA con FIDO2, detección de anomalías y contexto: hora, origen, patrones de comandos.

LinPEAS comprime en minutos lo que un atacante haría a mano en horas, pero no es silencioso. Accede a decenas de archivos sensibles en secuencia rápida y ejecuta comandos del sistema en volumen. Un auditd bien configurado con reglas SIEM que busquen ese patrón puede detectar la herramienta aunque el atacante la haya renombrado. La huella no está en el nombre del binario, está en lo que hace.

La defensa en profundidad no es un checklist que se completa: es el reconocimiento de que cada capa cubre lo que la anterior no ve. Autenticación por clave pública elimina el vector de fuerza bruta. MFA resiste el robo de credenciales. Fail2Ban reduce ruido. Menor privilegio limita el daño post-acceso. auditd y SIEM dan visibilidad sobre lo que ya entró. MITRE ATT&CK conecta los eventos dispersos con comportamiento adversario documentado. Ninguna de esas capas reemplaza a las demás.

Tabla de Mapeo MITRE ATT&CK

Relación entre cada acción ofensiva del laboratorio, la técnica MITRE ATT&CK correspondiente y el control defensivo que la detiene o detecta.

Lab	Acción Ofensiva	Técnica MITRE ATT&CK	Control Defensivo
Lab 1	Escaneo de puertos y superficie de acceso remoto	T1133 — External Remote Services (reconocimiento)	Firewall perimetral; deshabilitar servicios innecesarios
Lab 2	Fuerza bruta SSH con Hydra (diccionario)	T1110 — Brute Force	Fail2Ban; contraseñas robustas; migración a claves públicas
Lab 3	Ataque repetido; observación del bloqueo	T1110 — Brute Force (detección)	Fail2Ban (maxretry=3, bantime=3600); alertas en journalctl
Lab 4	Acceso SSH con credencial válida obtenida	T1078 — Valid Accounts	Deshabilitar PasswordAuthentication; MFA (FIDO2/passkeys); detección de anomalías
Lab 5	Enumeración post-acceso con LinPEAS	TA0007 — Discovery	auditd con reglas de enumeración; SIEM; principio de menor privilegio
Lab 6	Detección en logs; limpieza de cuenta y configuración	TA0001 — Initial Access (respuesta)	Monitoreo de journalctl/auditd; playbooks de respuesta a incidentes

¿Cómo Puedo Generar un Ingreso Económico a Partir de lo Visto en la Práctica?

Lo que se trabajó en esta práctica, reconocimiento de superficie, explotación de acceso inicial y detección de enumeración post-compromiso, es exactamente el flujo que cubre un pentest de infraestructura básico. Empresas pequeñas y medianas rara vez tienen a alguien que revise si su SSH acepta contraseñas, si sus usuarios tienen privilegios que no necesitan, o si tienen algo equivalente a auditd corriendo. Con las herramientas vistas, RustScan o Nmap para el perímetro, Hydra o validación manual de vectores de acceso, LinPEAS para simular enumeración interna, y un reporte que mapee hallazgos contra MITRE ATT&CK, es viable ofrecer auditorías de acceso inicial a ese segmento de mercado. El entregable no es técnico: es un documento que le dice al cliente qué vector usaría un atacante para entrar, qué encontraría adentro, y qué tiene que cambiar. Eso tiene valor concreto y no requiere certificaciones para empezar, requiere práctica documentada y saber explicar el riesgo en términos que no sean jerga.